

Burp Suite Lab

Lab task consists of the following values:

Request	GET /vulnerabilities/sqli/?id=1&submit=submit
Parameter tested	id
Original Value	1
Modified Value	2
Tool	Burp suite
Observation	The server sent a different response based on the modified parameter

Repeater Request

The screenshot displays the Burp Suite Repeater interface. The top menu bar includes Burp, Project, Intruder, Repeater, View, and Help. The main toolbar shows options like Intercept, Forward, and Drop. The Repeater tab is active, showing a list of requests. The selected request is a GET request to http://127.0.0.1:8080/vulnerabilities/sqli/. The Request tab is selected, showing the raw request details. The Inspector tab is also visible, showing the request attributes, query parameters, body parameters, cookies, and headers.

Time	Type	Direction	Method	URL	Status code	Length
08:07:10 29 Se...	HTTP	→ Request	GET	https://aus5.mozilla.org/update/3/GMP/140.11.0/20260514160037/Linux_x86_64-gcc3/en-US/esr/Linux%25206.19.14%2520kali-amd64%2520GTK%25203.24.52%2520Cibpulse%252017...		
08:08:01 29 Se...	HTTP	→ Request	GET	https://aus5.mozilla.org/update/3/SystemAddons/140.11.0/20260514160037/Linux_x86_64-gcc3/en-US/esr/Linux%25206.19.14%2520kali-amd64%2520GTK%25203.24.52%2520Cibpulse...		
08:09:53 29 Se...	HTTP	→ Request	GET	http://127.0.0.1:8080/vulnerabilities/csrf/		
08:12:48 29 Se...	HTTP	→ Request	POST	https://ds.mozilla.org/feeds		
08:15:14 29 Se...	HTTP	→ Request	GET	http://127.0.0.1:8080/security.php		
08:15:32 29 Se...	HTTP	→ Request	GET	http://127.0.0.1:8080/security.php		
08:20:57 29 Se...	HTTP	→ Request	GET	http://127.0.0.1:8080/vulnerabilities/sqli/		

Request

Pretty Raw Hex

```
1 GET /vulnerabilities/sqli/ HTTP/1.1
2 Host: 127.0.0.1:8080
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
```

Inspector

Request attributes: 2

Request query parameters: 0

Request body parameters: 0

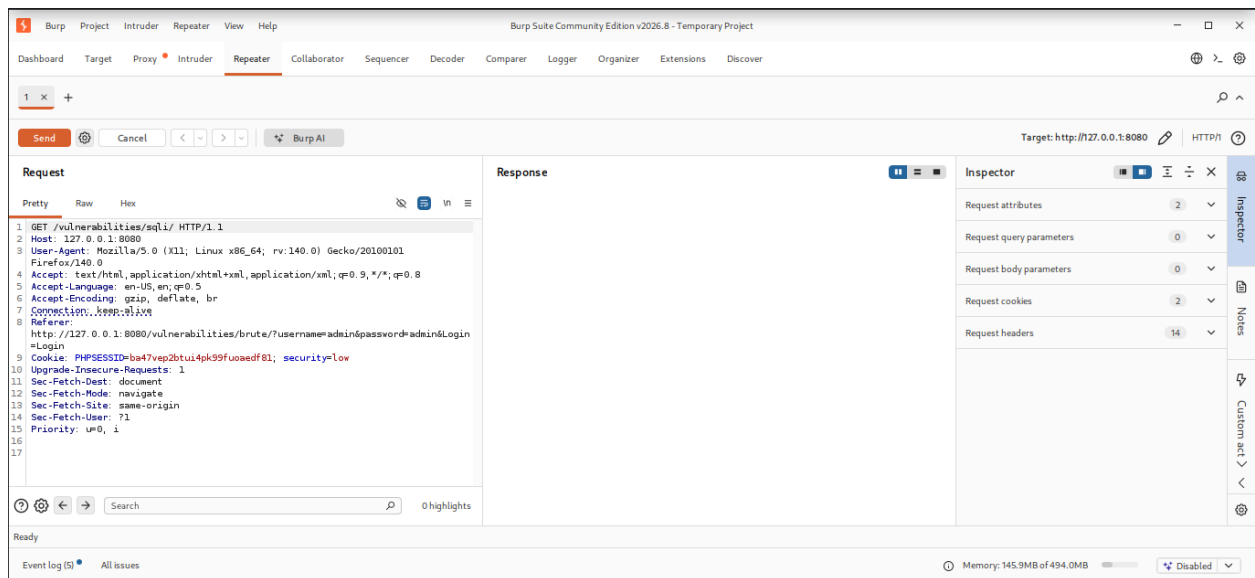
Request cookies: 2

Request headers: 14

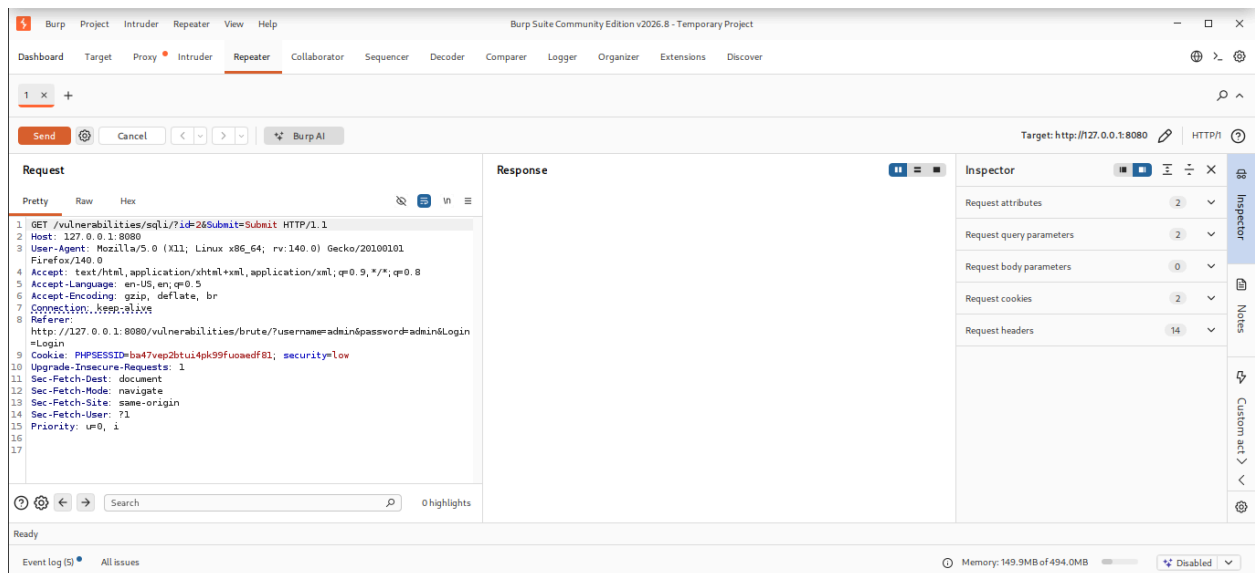
Event log (9) All issues

Memory: 145.9MB of 494.0MB

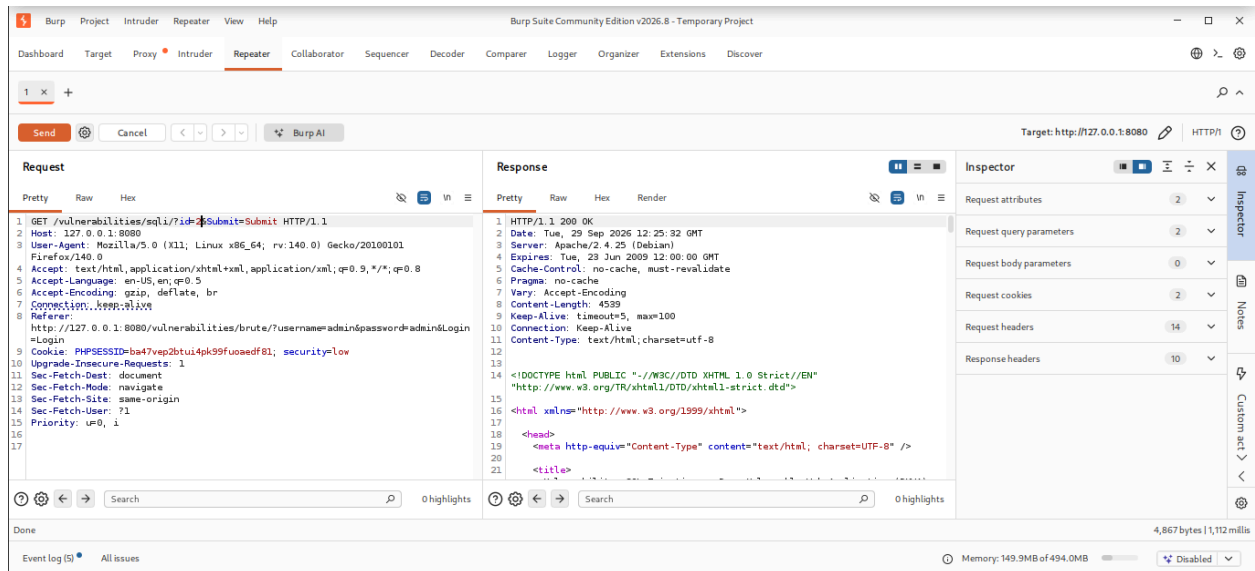
Repeater



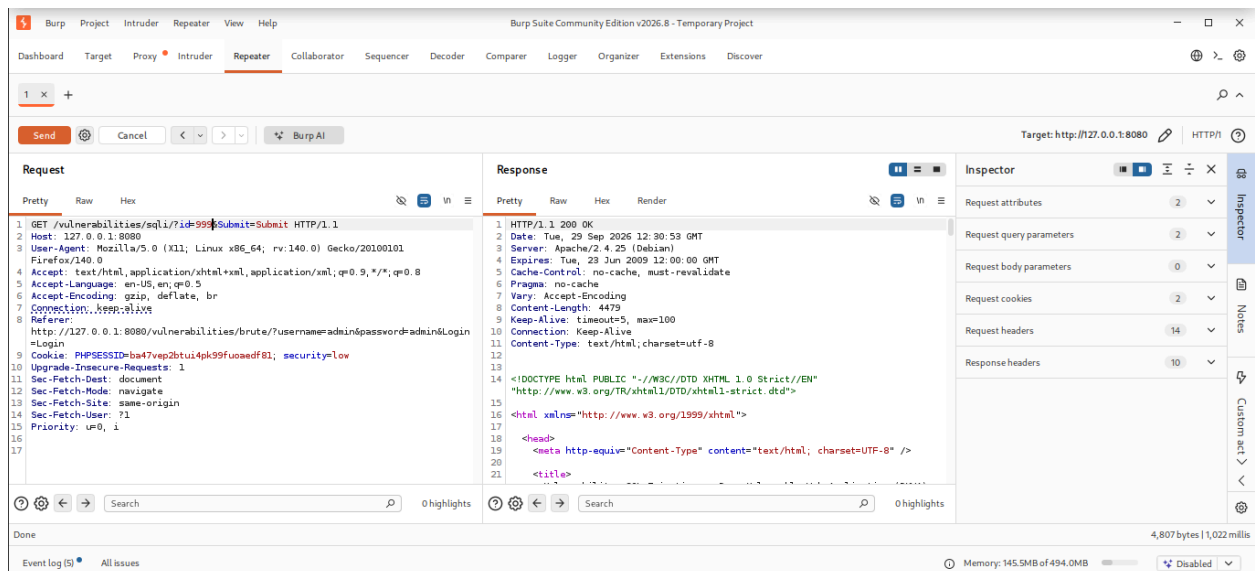
In the Get header change id=2 instead of id=1



Click on the send button and look at the response section



Now lets change to id=999



This is the core purpose of the repeater.
capture>modify>resend>compare the response

Intruder Request

Intercepted HTTP request details:

Time	Type	Direction	Method	URL	Status code	Length
08:07:10 29 Se...	HTTP	→ Request	GET	https://aus5.mozilla.org/update/3/GMP/140.11.0/2026051460037/Linux_x86_64-gcc3/en-US/esr/Linux%25206.19.14%2528kali-amd64%2520GTK%25203.24.52%252C1bpulse%252017...		
08:08:01 29 Se...	HTTP	→ Request	GET	https://aus5.mozilla.org/update/3/systemaddons/140.11.0/2026051460037/Linux_x86_64-gcc3/en-US/esr/Linux%25206.19.14%2528kali-amd64%2520GTK%25203.24.52%252C1bpulse...		
08:09:53 29 S...	HTTP	→ Request	GET	http://127.0.0.1:8080/vulnerabilities/csrf/		
08:12:48 29 Se...	HTTP	→ Request	POST	https://ads.mozilla.org/vlads		
08:15:14 29 Se...	HTTP	→ Request	GET	http://127.0.0.1:8080/security.php		
08:15:32 29 Se...	HTTP	→ Request	GET	http://127.0.0.1:8080/security.php		
08:20:57 29 Se...	HTTP	→ Request	GET	http://127.0.0.1:8080/vulnerabilities/qli/		
08:23:17 29 Se...	HTTP	→ Request	GET	http://127.0.0.1:8080/vulnerabilities/brute/?username=admin&password=admin&login=Login		
08:23:26 29 Se...	HTTP	→ Request	GET	http://127.0.0.1:8080/vulnerabilities/qli/		
08:27:48 29 Se...	HTTP	→ Request	POST	https://ads.mozilla.org/vlads		
08:50:05 29 Se...	HTTP	→ Request	POST	https://ads.mozilla.org/vlads		
08:50:12 29 Se...	HTTP	→ Request	GET	http://127.0.0.1:8080/vulnerabilities/brute/?username=admin&password=admin&login=Login		

Request

Pretty Raw Hex

```
1 GET /vulnerabilities/brute/?username=admin&password=admin&login=Login HTTP/1.1
2 Host: 127.0.0.1:8080
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://127.0.0.1:8080/vulnerabilities/brute/
```

Inspector

- Request attributes: 2
- Request query parameters: 3
- Request body parameters: 0
- Request cookies: 2
- Request headers: 14

Event log (5) All issues

Memory: 145.3MB of 494.0MB Disabled

Sent this http request to intruder

Intruder configuration:

Target: Update Host header to match target

Positions: Add \$ Clear \$ Auto \$

Selected request (1):

```
1 GET /vulnerabilities/brute/?username=admin&password=admin&login=Login HTTP/1.1
2 Host: 127.0.0.1:8080
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://127.0.0.1:8080/vulnerabilities/brute/
9 Cookie: PHPSESSID=ba7fvep2bui4pk39fuosedf01; security=low
10 Upgrade-Insecure-Requests: 1
11 Sec-Fetch-Dest: document
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-User: ?1
15 Priority: u=0, i
16
17
```

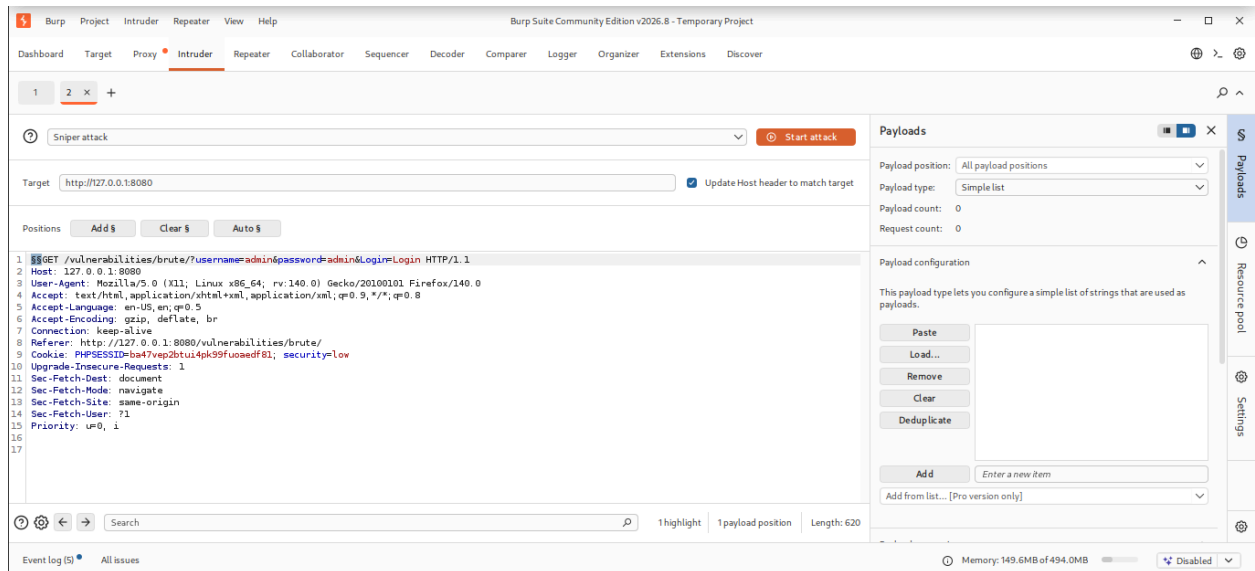
Payloads

To get started, highlight the part of the request or target you want to replace, then click Add \$ to set a payload position.

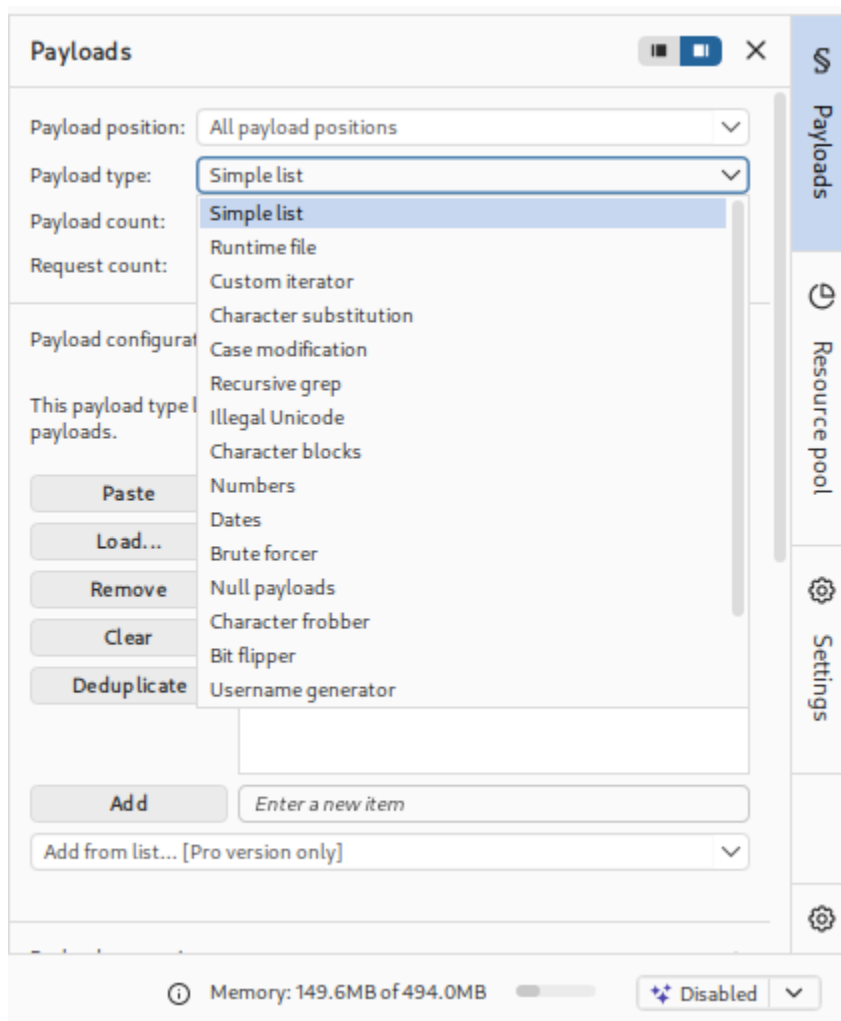
Event log (5) All issues

Memory: 145.3MB of 494.0MB Disabled

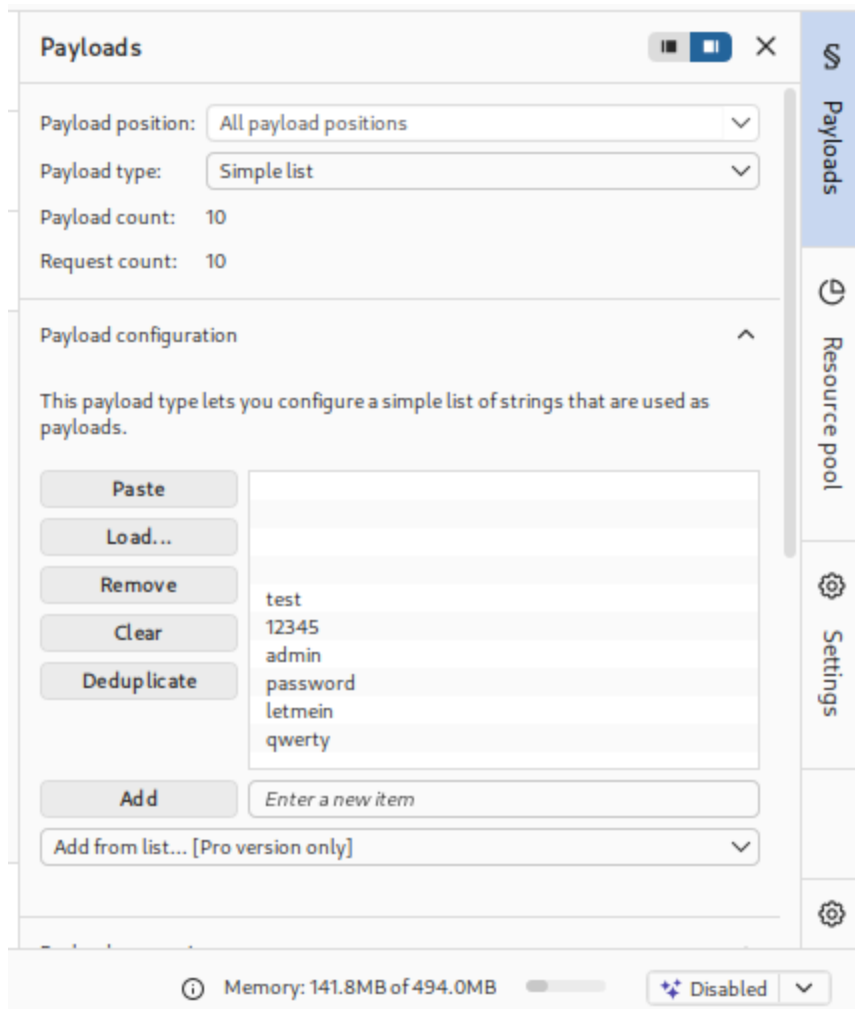
Then send to the position



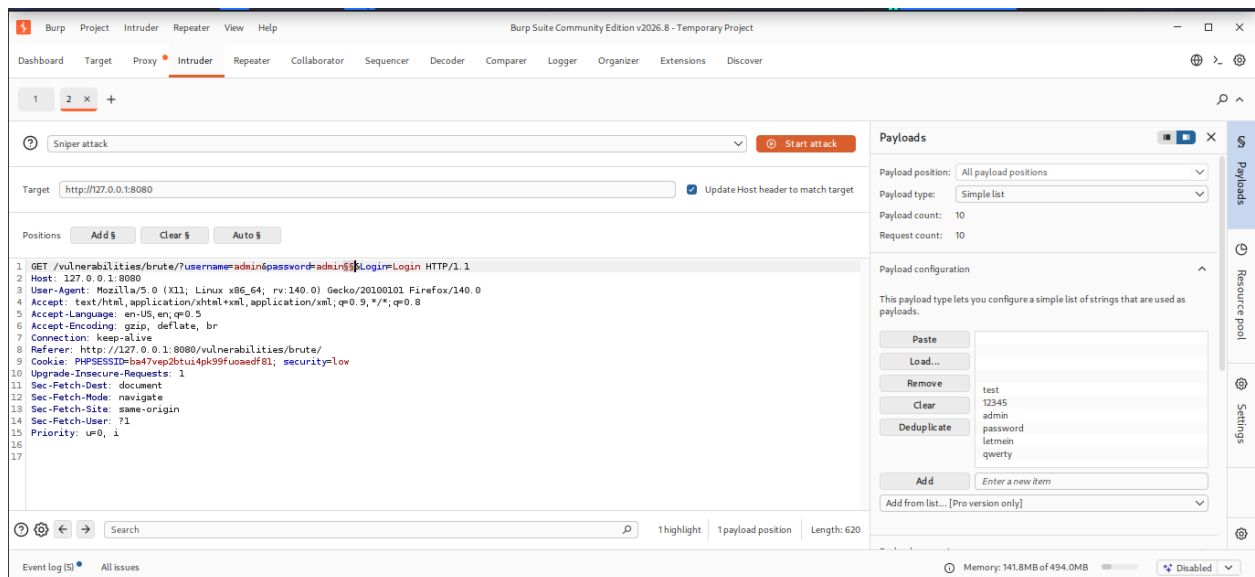
Set payload type to simple list



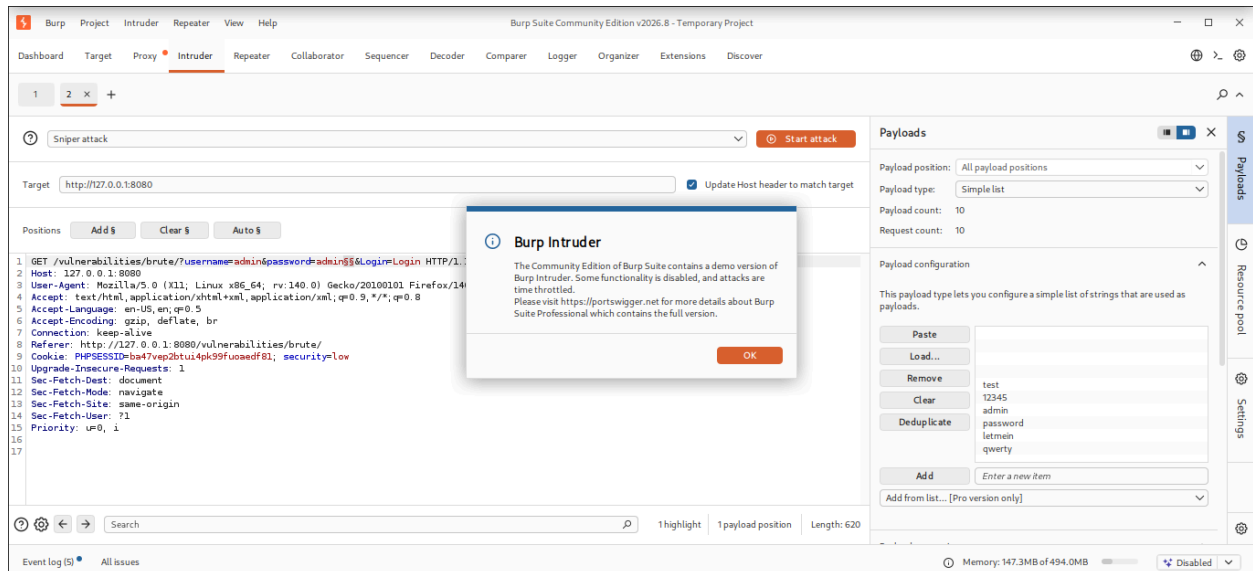
Then added a small test list



You will see payload in the request



Then click on the start attack button. Unfortunately we are using a community edition and it has limitation



What sensitive data was visible in intercepted requests?

The intercepted DVWA requests exposed several pieces of information in the HTTP request:

- **Session cookie (PHPSESSID)** identifies the user's active session and should be treated as sensitive.
- **DVWA security level cookie/parameter** such as `security=low`, which indicates the application's configured security level.
- **The login username** was visible in the request.
- **During** the brute-force exercise, the password value was transmitted as an HTTP parameter, making it visible to Burp.
- **Application parameters** for example, the SQL Injection request exposed parameters such as `id=1`.
- **HTTP headers** such as Host, User-Agent, Accept, and other request metadata were visible.